Progettazione di Rete complessa azienda Theta, Topologia e preventivo con analisi dettagliata dei costi

Documento interno, vietata la pubblicazione e la divulgazione

Sommario

Sommario 1
Report Progetto: Infrastruttura di Rete per la Compagnia Theta 1
1. Executive Summary 2
2. Obiettivi del Progetto 2
3. Architettura di Rete 2
3.1 Topologia Fisica (Edificio 1) 3
3.2 Topologia Fisica (Edificio 2) 3
3.3 Segmentazione VLAN e Subnetting (Edificio 1) 4
3.4 Segmentazione VLAN e Subnetting (Edificio 2) 4
3.5 Router Inter – VLAN (Layer 3) 5
3.6 Sottoreti Dispositivi di Sicurezza 5
4. Analisi dei Costi (Edificio 1) 5
4.1 Analisi dei Costi (Edificio 2) 7
4.2 Tempi di Realizzazione 8
5. Dispositivi di Sicurezza 9
5.1 Firewall Perimetrale 9
5.2 Sistemi IDS/IPS 9
5.3 Pianificazione della Zona DMZ e Web Server 9
5.4 Implementazione e Sicurezza del Server NAS 9
6. Testing di Sicurezza Automatizzato e Risultati 10
6.1 Strumenti di Testing Sviluppati 10
6.2 Risultati Scansione Porte 10
6.3 Risultati dei Test HTTP 12
6.4 Network Sniffer 14
7. Raccomandazioni di Sicurezza 14
Piano per un web server aziendale 15
Cosa spegnere o chiudere 15
Cosa sistemare 15
8. Team e Suddivisione dei Ruoli 15
9. Conclusioni 16

Report Progetto: Infrastruttura di Rete per la Compagnia Theta

1. Executive Summary

Il presente documento costituisce il report tecnico relativo alla progettazione, implementazione e validazione dell'infrastruttura di rete della Compagnia Theta, sviluppato dal gruppo White Russian Hats.

La compagnia Theta opera in un edificio che si sviluppa su 6 piani, con una dotazione complessiva di 120 postazioni di lavoro (dunque 20 per piano). A seguito dell'espansione aziendale, è stata acquistata una seconda sede situata a 250 metri di distanza, si trova all'interno della zona PIP del Comune di Cavenago di Brianza. La nuova sede si sviluppa su 3 piani con un totale complessivo di 90 postazioni di lavoro (30 per piano).

Il progetto si propone di progettare una topologia di rete completa, moderna, scalabile e sicura, per entrambe le sedi, includendo dispositivi di connettività come Switch e router, sistemi di sicurezza esterna ed interna (Firewall, IDS/IPS), servizi di NAS ed infine una zona demilitarizzata (DMZ).

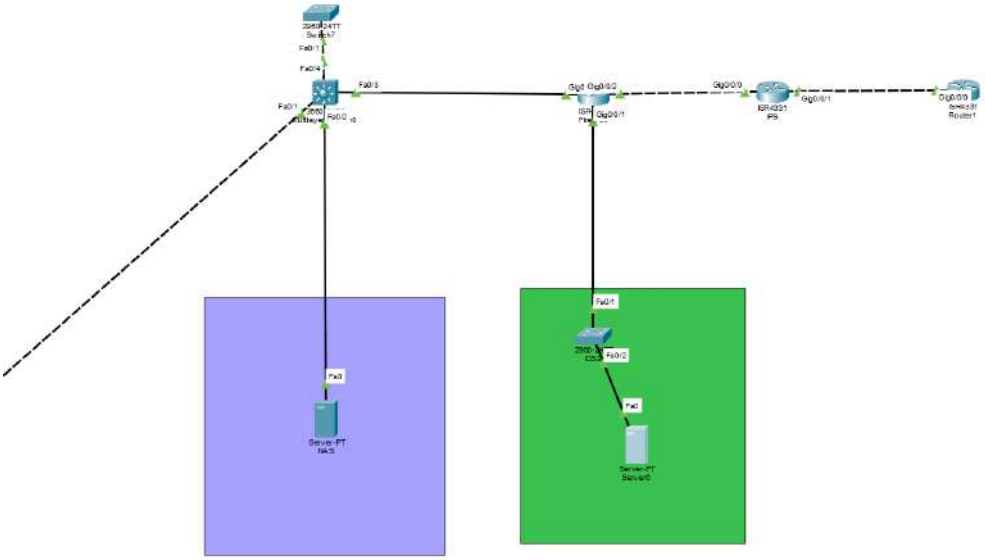
Una volta completata l'infrastruttura, il gruppo White Russian Hats ha sviluppato strumenti di testing automatizzato, facendo uso del linguaggio Python per la verifica della sicurezza dei servizi esposti.

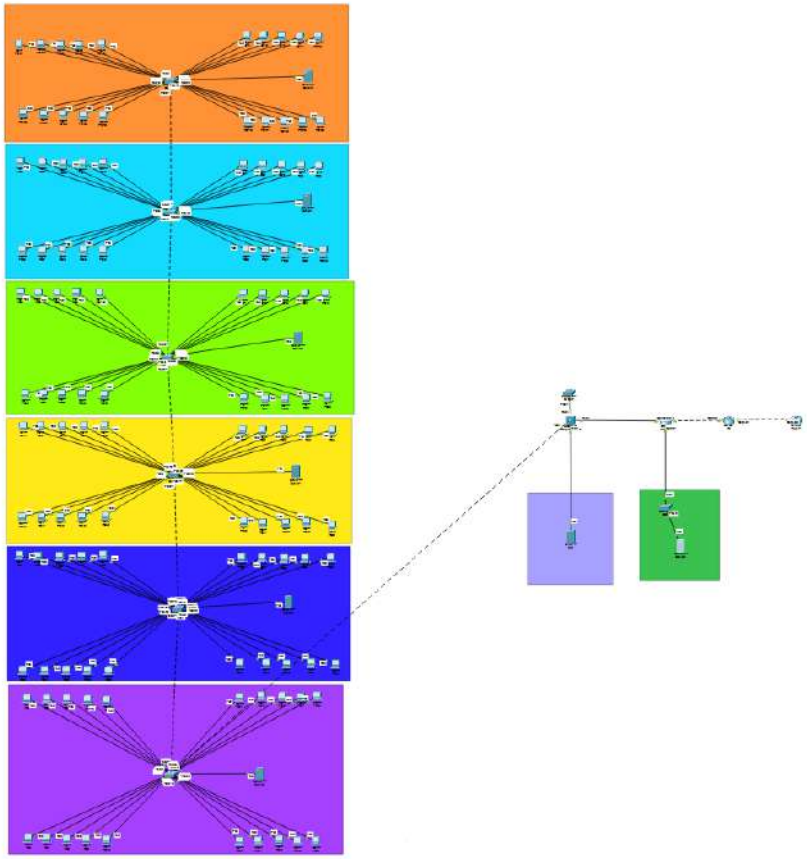
2. Obiettivi del Progetto

- Progettazione topologia di rete scalabile e sicura
- Segmentazione della rete in VLAN per reparto
- Implementazione di dispositivi di sicurezza (Firewall, IDS/IPS)
- Esposizione controllata di servizi web in DMZ
- Testing automatizzato della sicurezza
- Espansione multi-sede replicando gli standard di sicurezza della sede principale
- Raccomandazioni basate sui risultati

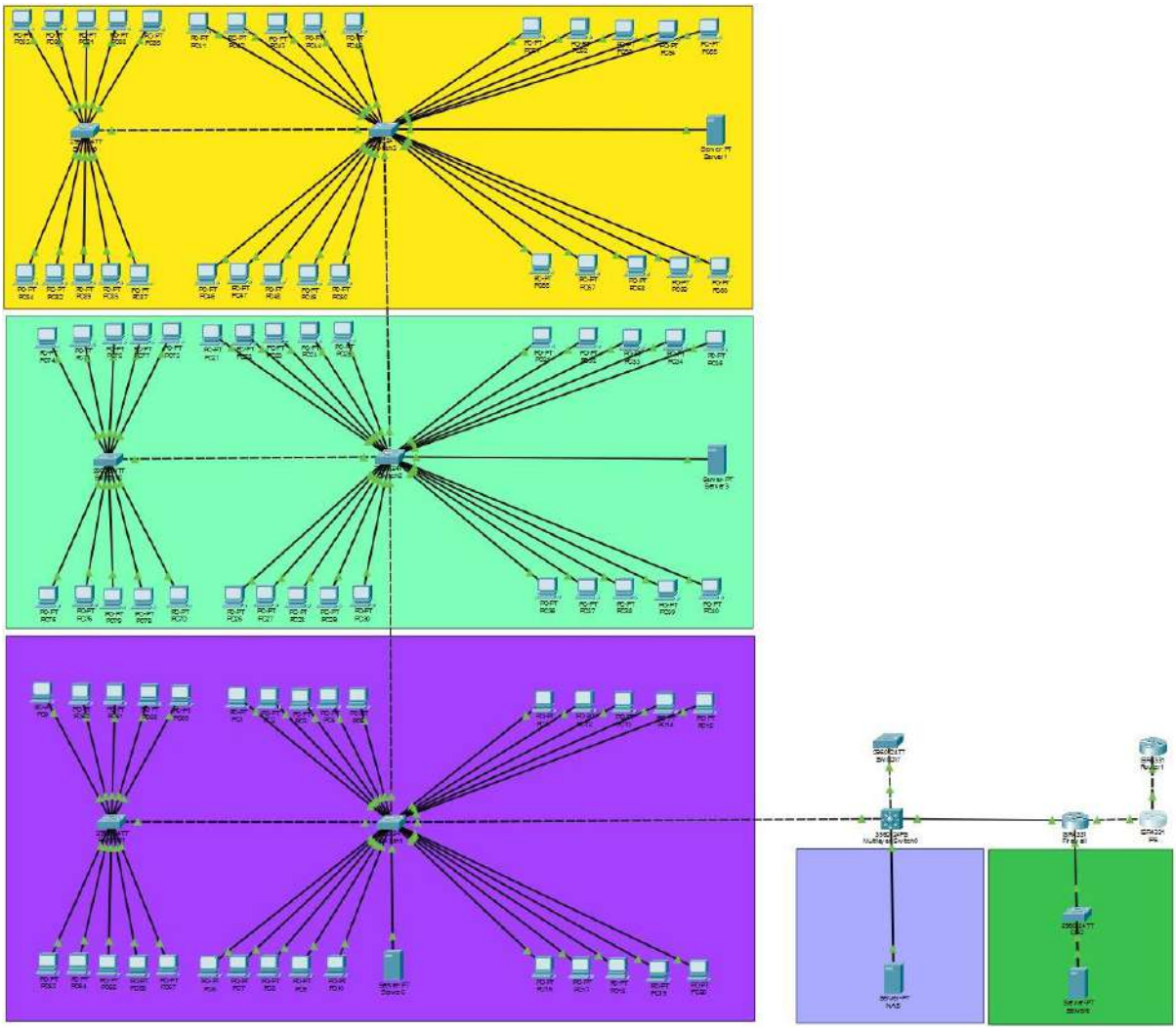
3. Architettura di Rete

3.1 Topologia Fisica (Edificio 1)





3.2 Topologia Fisica (Edificio 2)



3.3 Segmentazione VLAN e Subnetting (Edificio 1)

L'infrastruttura è stata progettata con una segmentazione logica precisa in modo da isolare i flussi di traffico tra i diversi piani e migliorare le prestazioni e la sicurezza.

Configurazione VLAN

- 6 VLAN dedicate ai vari piani, (da VLAN 10 a VLAN 15)
- 2 VLAN dedicate, una al NAS (VLAN 20) e una al DMZ (VLAN 30)
- Ad ogni VLAN è stata applicata una subnet mask /26 (255.255.255.192), con blocchi da 64 indirizzi IP per ogni piano.

Configurazione degli Switch

- I collegamenti tra gli Switch di piano sono stati configurati con la modalità Trunk, consentendo il trasporto di più VLAN su un unico collegamento fisico.
- Le porte dedicate alle postazioni client sono state configurate in modalità Access.

3.4 Segmentazione VLAN e Subnetting (Edificio 2)

L'infrastruttura della seconda sede è progettata con un'architettura a tre livelli, replicando gli standard della sicurezza della sede principale e adattandoli alla nuova struttura su 3 piani.

Configurazione VLAN

Sono state create 5 VLAN in totale:

- 3 VLAN dedicate ai piani (VLAN 10, VLAN 11, VLAN 12) ciascuna con il proprio Switch di accesso e Switch Multilayer.
- 2 VLAN dedicate ai servizi VLAN 20 per la rete NAS e VLAN 30 per la zona DMZ.

3.5 Router Inter – VLAN (Layer 3)

Per poter consentire la comunicazione controllata tra le diverse VLAN, è stato implementato il routing-inter-VLAN sullo Switch Multilayer.

Configurazione implementata

- Abilitazione del routing IP sullo Switch Multilayer;
- Configurazione delle interfacce virtuali (SVI), che fungono da Gateway predefinito per tutte le sottoreti dei piani;
- Ogni SVI è stata configurata con l'indirizzo IP della propria subnet.

3.6 Sottoreti Dispositivi di Sicurezza

Per garantire la sicurezza dei dispositivi (Multilayer, Firewall, IPS e router), sono state implementate 3 sottoreti con subnet-mask /30, (255.255.255.252).

- Multilayer – Firewall 192.168.100.0/30
- Firewall – IPS 192.168.101.0/30
- IPS – Router 192.168.102.0/30

4. Analisi dei Costi (Edificio 1)

//	Dispositivo	Modello	Q.tà	Prezzo Unit.	Totale	Fornitore
Rete	Switch di Piano	Cisco C9200L-4G-E	6	1.487,50	8.925,00	it-market.com
	Core Switch	Cisco C9300-24T-A	1	2.796,50	2.796,50	It.market.com
	Router	Cisco Catalyst C8200-1N-4T	3	2.201,50	6.604,50	it-market.com
Endpoint	Mini PC Aziendali	Lenovo ThinkCentre neo 50q Gen 6	120	889,33	107.919,60	lenovo.com
	Monitor	HP 3 Pro 23.8 -324pe	120	138,59	16.630,80	hp.com
	Tastiere + Mouse	Logitech MK295 Silent Wireless	120	29,90	3.588,00	amazon.it
Security	Firewall Perimetrale	Cisco Secure Firewall 1230	1	8.135,75	8.135,75	itosolutions.net
	Switch IDS	Cisco C9300-24S-A	2	12.971,00	25.942,00	it.market.com
	Server	Cisco UCSC-C220-M3SBE	8	6.545	52.360	It.market.com
	TOTALE				232.902	
Servizi IDS/IPS	Gestione centralizzata	Software di gestione unificata	1	3.000,00	3.000,00	
	Infrastruttura passiva	TAP, transceiver e cablaggio strutturato	1	2.000,00	2.000,00	
	Installazione e collaudo	Manodopera specializzata e testing	1	6.000,00	6.000,00	
	TOTALE				11.000,00	
	SOC esterno 24/7	Monitoraggio sicurezza	1	30.000,00	30.000,00	
	Supporto e rinnovi	Manutenzione piattaforma e licenze	1	4.000,00	4.000,00	

	TOTALE				34.000	
	Costo manodopera e configurazione		1	14.500	14.500	
	TOTALE COMPLESSIVO	1 anno di rinnovi compresi			**292.402,00 + iva**	

4.1 Analisi dei Costi (Edificio 2)

//	Dispositivo	Modello	Q.tà	Prezzo Unit.	Totale	Fornitore
Rete	Switch di piano	Cisco C9200L-24T-4G-E	6	1.487,50	8.925	it.market.com
	Core Switch	Cisco C9300-24T-A	1	2.796,50	2.796,50	it.market.com
	Router	CiscoCatalyst C8200-1N-4T	3	2.201,50	6.604,50	it.market.com
Endpoint	Mini PC Aziendali	Lenovo ThinkCentre neo 50q Gen6	90	889,33	80.039,70	lenovo.com
	Monitor	HP 3 Pro 23,8"- 32pe	90	138,59	12.473,10	hp.com
	Tastiere + Mouse	Logitech MK295 Silent Wireless	90	29,90	2.691,00	amazon.it
Security	Firewall	Cisco Secure Firewall 1230	1	8.135,75	8.135,75	itosolutions.net

	Switch IDS	Cisco C9300-24S-A	2	12.971,00	25.942,00	it.market.com
	Server	Cisco UCSC-C220-M3SBE	5	6.545,00	32.725	it.market.com
	TOTALE				180.333	
Servizi IDS/IPS	Gestione centralizzata	Software di gestione unificata	1	3.000	3.000	
	Infrastruttura passiva	TAP, transceiver e cablaggio strutturato	1	1.850	1.850	
	Installazione e collaudo	Manodopera specializzata e testing	1	6.000	6.000	
	TOTALE				10.850	
	SOC esterno 24/7	Monitoraggio sicurezza	1	30.000	30.000	
	Supporto e rinnovi	Manutenzione piattaforma e licenze	1	4.000	4.000	
	TOTALE				34.000	
	Costo manodopera e configurazione				14.500	
	TOTALE COMPLESSIVO	(1 anno di rinnovi compresi)			**239.683,00 +iva**	

4.2 Tempi di Realizzazione

Di seguito riportate le fasi di implementazione dell'infrastruttura di rete, con le relative durate stimate.

Fase	Durata stimata
Progettazione e ordini	1settimana
Cablaggio e installazione apparati	2 settimane
Configurazione e VLAN	1 settimana

IDS/IPS in sola rivelazione e tuning	2-3 settimane
Attivazione del blocco e collaudo	A seguire

5. Dispositivi di Sicurezza

5.1 Firewall Perimetrale

Configurato con NAT per l'accesso a Internet e per il filtraggio del traffico. Permette solo traffico HTTP/HTTPS verso la DMZ e blocca tutto il traffico in ingresso non autorizzato.

5.2 Sistemi IDS/IPS

Tre sensori posizionati strategicamente:

- **IPS-1**: Posizionato tra router perimetrale e firewall aziendale.
- **IDS-2**: Collegato allo Switch della DMZ e monitora traffico diretto dal Web Server
- **IDS-3**: Collegato al Core Switch monitora traffico delle VLAN

5.3 Pianificazione della Zona DMZ e Web Server

Il Web Server (Metasploitable2) è isolato in una zona demilitarizzata accessibile dall'esterno solo sulla porta 80 (HTTP) tramite NAT.

Architettura della DMZ (zona verde)

- La DMZ è stata creata come segmento di rete isolato e protetto dal router/firewall
- Il Web Server è stato posizionato all'interno della DMZ con la configurazione di indirizzo IP, gateway e servizio HTTP

5.4 Implementazione e Sicurezza del Server NAS

Il server NAS è stato implementato come risorsa per la condivisione dei dati aziendali, con particolare attenzione alla sicurezza degli accessi.

Configurazione di rete

- Il NAS è stato collocato in una VLAN dedicata, per limitare l'esposizione e per poter controllare gli accessi
- Sono stati configurati gli indirizzi IP, subnet mask e gateway per garantire la comunicazione inter-VLAN

Configurazione dei servizi

- Il servizio FTP sul NAS consente il trasferimento dei file
- Sono stati creati utenti tramite una gestione dei permessi: lettura, scrittura, eliminazione e privilegi amministrativi

6. Testing di Sicurezza Automatizzato e Risultati

6.1 Strumenti di Testing Sviluppati

La squadra ha sviluppato tre strumenti di testing automatizzato in Python:

1. **Port Scanner**: scansione delle porte comuni tramite socket TCP
2. **HTTP Methods Scanner**: enumerazione dei verbi HTTP abilitati (modalità passiva e attiva)
3. **Network Sniffer**: cattura e analisi del traffico di rete in tempo reale

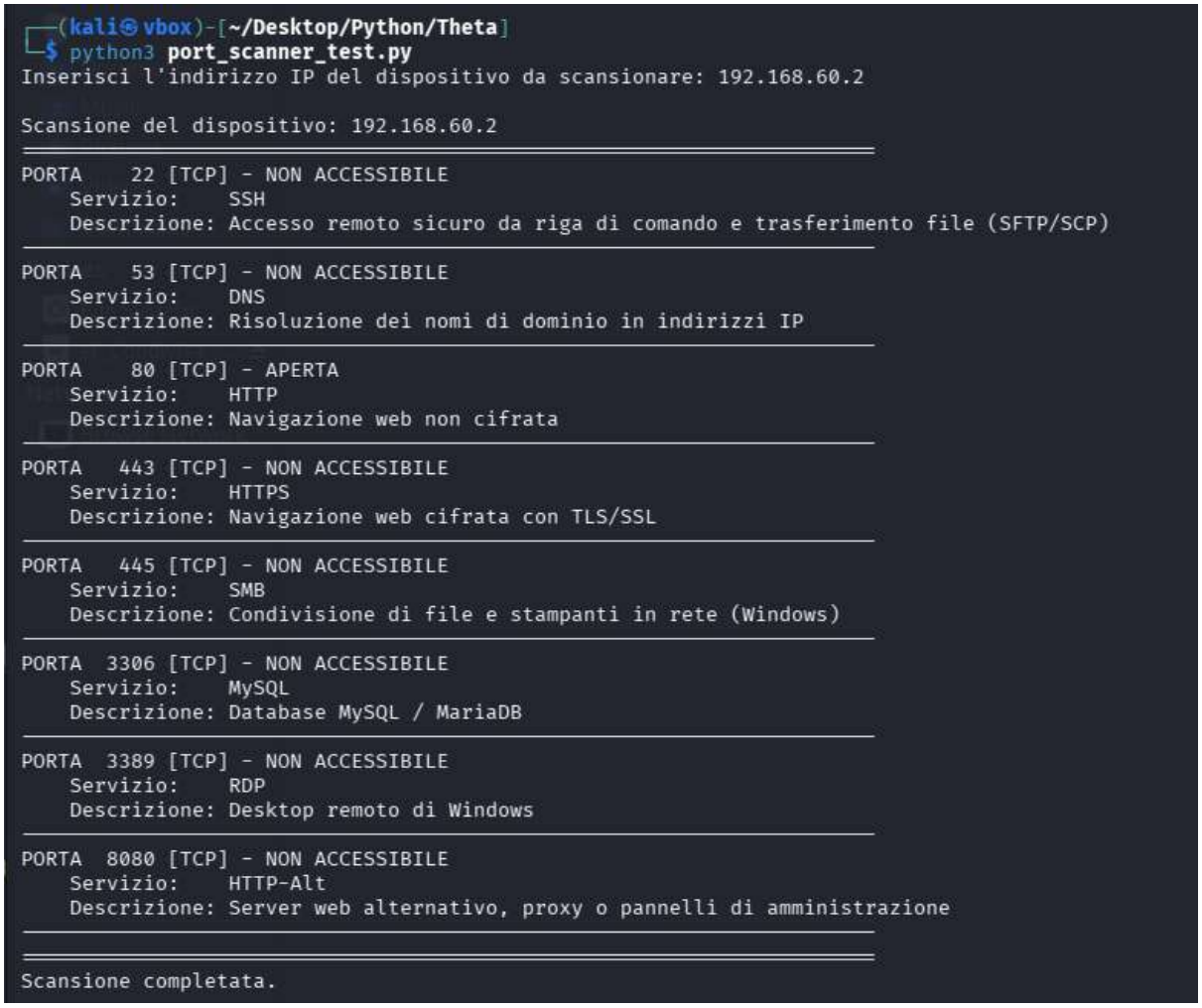
Di seguito si allegano i risultati di ogni test:

6.2 Risultati Scansione Porte



Lo script Port Scanner è stato eseguito senza il firewall attivo quindi, come possiamo notare, tutte le porte risultano accessibili, anche quelle non necessarie, ampliando così la superficie di attacco.

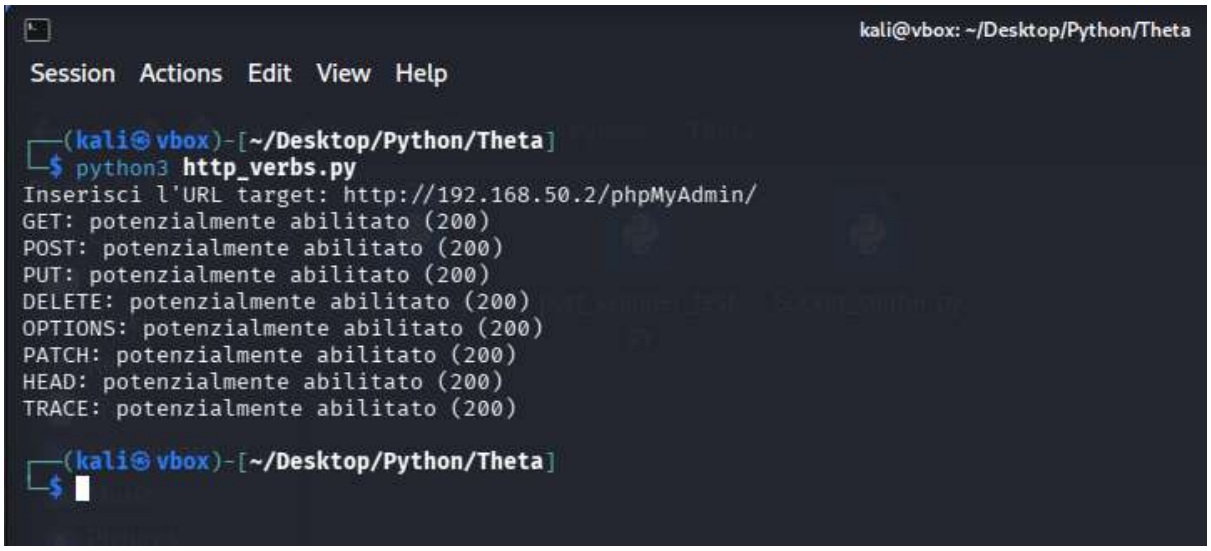
Successivamente abbiamo attivato e configurato il firewall ottenendo questo secondo risultato dove possiamo vedere che le porte non necessarie alla funzione sono state filtrate.



Lo script Port Scanner è stato eseguito in modo da avere un firewall perimetrale efficace.

In questo modo risulta aperta solo la porta 80 (HTTP), mentre tutte le altre porte sono state filtrate e non risultano accessibili.

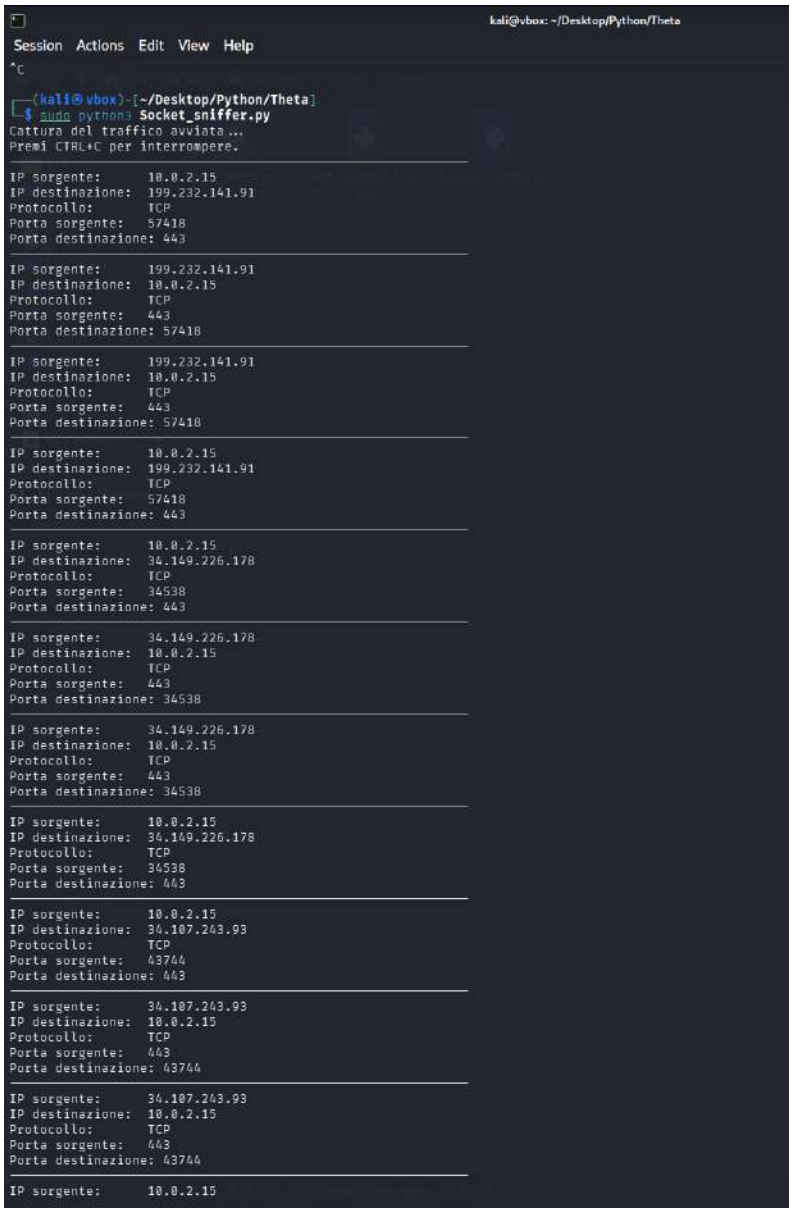
6.3 Risultati dei Test HTTP



Output dell'analisi del metodo HTTP abilitati sul server in DMZ. Il programma esegue richieste dei verbi al server riportando la risposta ricevuta in base al codice.

6.4 Network Sniffer

Lo sniffer è stato utilizzato per validare la visibilità del traffico HTTP in chiaro, dimostrando la necessità di implementare HTTPS per proteggere le credenziali di accesso ai servizi web.



7. Raccomandazioni di Sicurezza

Piano per un web server aziendale

Per un web server la regola è semplice: **devono essere raggiungibili solo HTTPS (e HTTP per il redirect), più SSH dalla rete di amministrazione**. Il resto va chiuso o isolato.

Cosa spegnere o chiudere

Porta	Azione	Motivo
445 SMB	Disattivare il servizio	Un web server non deve condividere file in rete. È il vettore classico di ransomware e movimento laterale.
53 DNS	Disattivare, a meno che non sia voluto	Il DNS aziendale va su un server dedicato, non sul web server.
3306 MySQL	Mettere in ascolto solo su `127.0.0.1` (o spostare il DB su un altro host)	Il database non deve essere raggiungibile dalla rete.
22 SSH	Tenere, ma solo da IP/VLAN di amministrazione	Serve per la gestione, non per tutta la LAN.

Cosa sistemare

HTTPS (443) non è accessibile. Per un sito aziendale è il problema principale. Serve un certificato valido (Let's Encrypt, o una CA interna se il sito è solo intranet), la 443 attiva e il redirect 80 → 443. Poi aggiungere HSTS, disabilitare TLS 1.0/1.1 e verificare la configurazione con `testssl.sh` o SSL Labs, se il sito è pubblico.

Se il database è sullo stesso server, usare `bind-address = 127.0.0.1` e un utente dedicato all'applicazione, con privilegi minimi sul solo schema necessario. Niente `root` per l'applicazione.

-

8. Team e Suddivisione dei Ruoli

Di seguito la ripartizione delle responsabilità, poiché il progetto ha richiesto competenze trasversali, alcuni ruoli sono stati condivisi tra più membri per garantire una maggiore coesione tecnica, sicurezza e gestione del progetto.

- **Network Architect & Lead Network Admin - Francesco Valentini**: Progettazione della topologia di rete fisica e logica, definizione dell'indirizzamento IP e delle VLAN, configurazione operativa di Switch, router e routing inter-VLAN.
- **Network Admin & Security Specialist - Samuele Colasuonno**: Configurazione operativa dei dispositivi di rete. Ha inoltre contribuito alla configurazione dei dispositivi di sicurezza.
- **Network Admin & Security Specialist - Federico Lattanzi**: Configurazione condivisa dell'infrastruttura di rete. Ha guidato la progettazione dei dispositivi di sicurezza.
- **Python Developer (Security Testing) - Daniele Perri**: Sviluppo completo degli strumenti di testing automatizzato in Python: script per la scansione delle porte e script per il test dei verbi HTTP (GET, POST, PUT, DELETE).
- **Hardware & Cost Analyst – Simone Varriale**: Ricerca di mercato e analisi commerciale dell'hardware di rete. Ha raccolto i prezzi unitari di Switch, router, firewall e dispositivi di sicurezza per elaborare il preventivo finale dei costi da presentare alla direzione aziendale.
- **Project Manager & Report Lead – Isabel Carosiello**: Raccolta e integrazione di tutte le informazioni tecniche, commerciali prodotte dai membri, stesura del report finale.

9. Conclusioni

Il presente progetto ha raggiunto l'obiettivo di progettare, implementare e validare un'infrastruttura di rete moderna, scalabile e sicura per la compagnia Theta. L'architettura finale copre la sede principale e la sede secondaria.

L'implementazione di un perimetro di sicurezza composto da un Firewall, una Zona Demilitarizzata per l'isolamento dei servizi web e un sistema ibrido di 1 IPS e 2 IDS, ha fornito una difesa a più livelli (Defense-in-Depth) contro minacce esterne e movimenti interni.

La fase di testing automatizzato svolta mediante script Python sviluppati dalla squadra, ha permesso di validare la sicurezza dell'infrastruttura. L'analisi ha confermato il corretto funzionamento dei servizi di base, e dopo l'applicazione delle

regole, solo la porta 80 (HTTP) rimane esposta, riducendo drasticamente la superficie d'attacco.

Le raccomandazioni fornite nella sezione 7 costituiscono la roadmap per mitigare i rischi.

In conclusione, l'infrastruttura progettata dal gruppo White Russian Hats si dimostra solida e pronta a supportare le operazioni aziendali quotidiane su entrambe le sedi, a condizione che vengano applicate le misure suggerite a seguito dei test di sicurezza.